

认证机制漏洞报告（Lab1：用户名通过不同回复枚举）

1. 漏洞名称

信息泄露与暴力破解（Username Enumeration & Password Brute-force）

2. 漏洞等级

高危（High）

3. 漏洞描述

该网站的登录功能存在认证机制缺陷。当提交不存在的用户名时，页面返回“用户名无效”；而当提交存在的用户名但密码错误时，页面返回“密码错误”。攻击者可以利用这个响应差异，通过自动化工具（Burp Intruder）枚举出系统中的有效用户名，再针对该用户进行密码字典爆破，最终成功登录受害者账户。

4. 漏洞位置

请求方式：POST /login

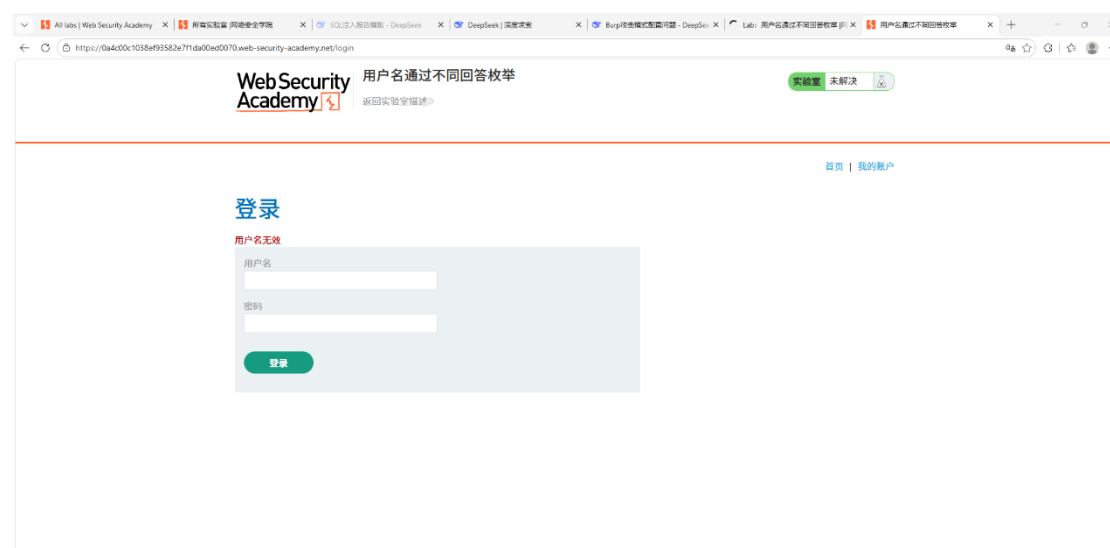
漏洞参数：username（用户名枚举）；password（密码爆破）

5. 漏洞复现过程

第一步：手工测试，发现响应差异

访问登录页面，尝试输入不存在的用户名（如 ad），页面提示“用户名无效”。

图 1：登录页面提示“用户名无效”



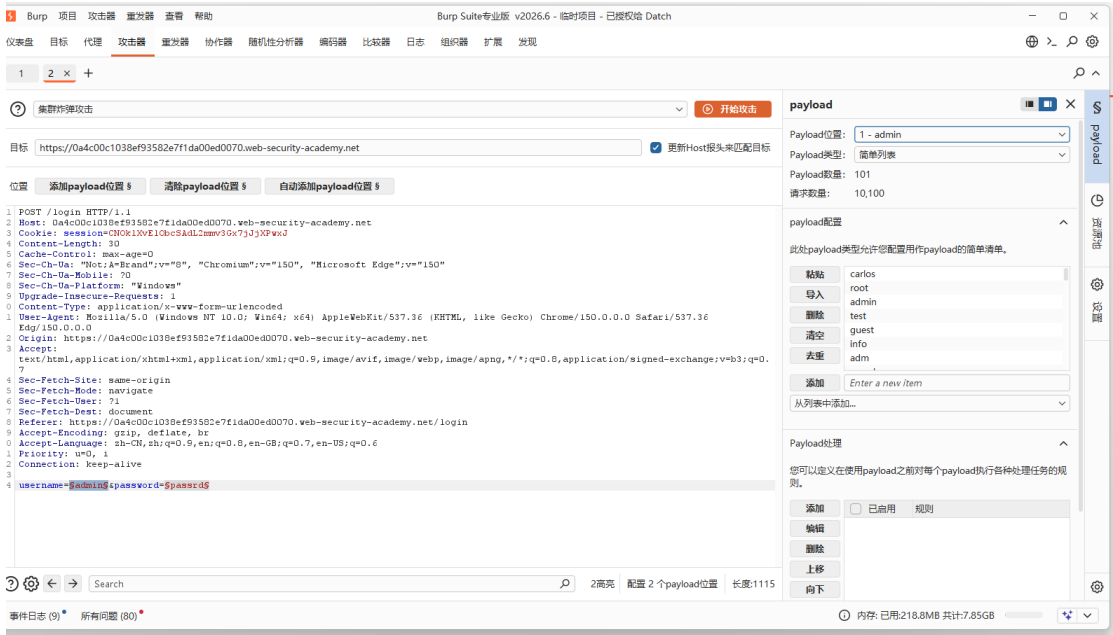
说明：明确的错误提示信息，为攻击者提供了枚举用户名的侧信道。

第二步：使用 Burp Intruder 枚举有效用户名

将登录请求发送至 Burp Intruder，使用 **Sniper（狙击手）** 攻击模式。将 username 参

数设为 Payload 位置，密码固定为 123456，加载“候选人用户名”字典进行自动枚举。

图 2: Burp Intruder 配置用户名枚举

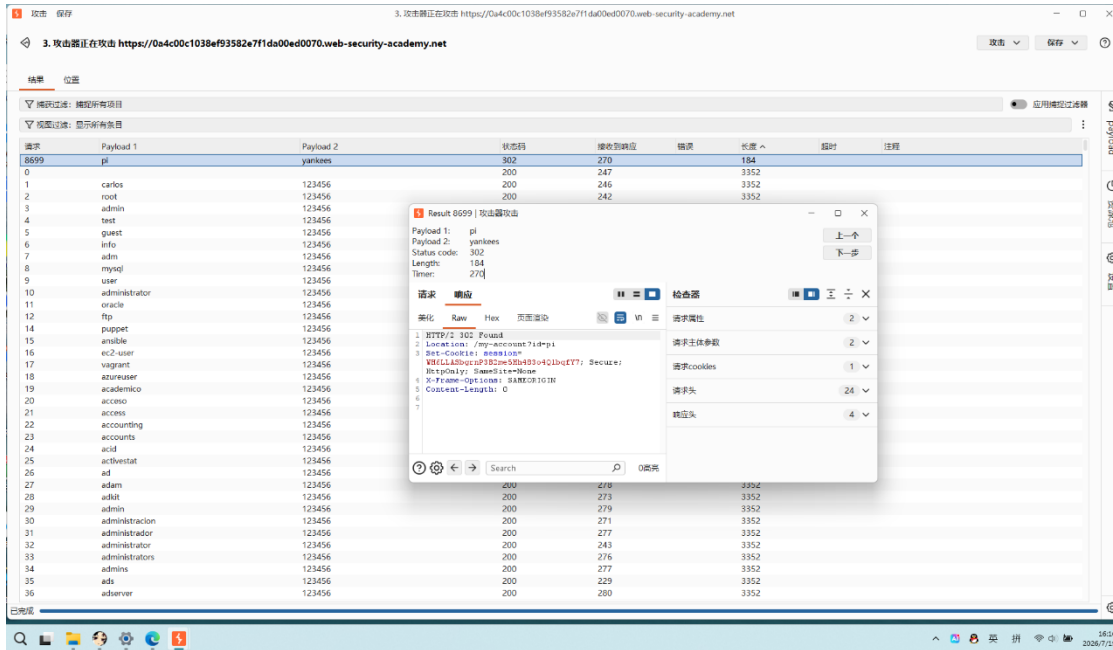


说明：通过自动化枚举，观察不同用户名导致的响应差异。

第三步：分析枚举结果，成功发现有效用户

攻击完成后，分析 Burp 结果列表。大多数请求返回了 Invalid username，但其中一个请求（Payload 为 pi）返回了 Incorrect password，且响应长度和状态码明显不同（返回 302 跳转而非 200）。

图 3: Burp Intruder 结果分析，发现有效用户 pi



说明：通过筛选 302 状态码，成功确认有效用户名。

第四步：针对有效用户进行密码暴力破解

已知用户名 pi 后，设置第二个 Payload 位置在 password 参数上，用户名固定为 pi，加载“候选密码”字典进行第二轮 Sniper 攻击。从结果中筛选出返回 302 的请求，获取到正确密码（本例中为 yankees）。

第五步：成功登录并解决问题

使用枚举出的用户名 pi 和密码 yankees 登录网站。

图 4：成功登录 pi 账户，解决实验



说明：验证了枚举出的凭证有效，实验完成。

6. 漏洞原理

该漏洞属于认证机制中的信息泄露与暴力破解：

1. **枚举漏洞**：服务器在处理登录请求时，对“用户不存在”和“密码错误”这两种情况返回了不同的前端提示，作为侧信道让攻击者能够准确区分有效用户。
2. **暴力破解漏洞**：系统没有对登录失败进行限制（如 IP 锁定、验证码），使得攻击者可以在短时间内对所有密码进行自动化尝试。

7. 漏洞影响

- **账号接管**：攻击者可遍历出所有系统用户，并利用自动化工具轻易攻陷大量弱密码账号。
- **权限提升**：若管理员账号存在弱密码，将直接导致整个系统被接管。

8. 修复建议

- ① **统一错误提示信息**：对于“用户不存在”和“密码错误”，服务器应返回完全相同的通

用错误信息（如：“用户名或密码错误”），防止枚举。

② **实施登录速率限制 (Rate Limiting)**：限制同一 IP 或同一账号在短时间内的失败次数，超出则锁定一段时间或弹出 CAPTCHA 验证码。

③ **强制强密码策略**：要求用户设置高复杂度密码，阻止字典攻击。

9. 工具

- **Burp Suite** (Intruder 模块进行自动化枚举与暴力破解)
- **PortSwigger Web Security Academy** (靶场平台)